PRIVACY POLICY

POL-004 | Issued under the Information Management Framework

Document ID: POL-004
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Data Protection Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Privacy Policy
Document ID	POL-004
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Data Protection Officer
Custodian	Legal / Compliance
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	GDPR (EU) 2016/679, UK GDPR, CCPA / CPRA (California), HIPAA (45 CFR Parts 160 and 164), applicable local privacy legislation

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes mandatory requirements for the collection, use, storage, transfer, retention, and disposal of personal data at [Company Name]. It governs how the company fulfils its obligations under applicable privacy legislation, including the General Data Protection Regulation (GDPR), UK GDPR, California Consumer Privacy Act (CCPA/CPRA), and the Health Insurance Portability and Accountability Act (HIPAA).

Privacy is not only a legal obligation — it is a condition of trust with the employees, patients, clinical trial participants, customers, and partners whose data [Company Name] processes. This Policy operationalises that trust by setting binding requirements that apply to all personal data processing activities, regardless of business unit or geography.

> **NOTE:** This is an internal governance policy. It is distinct from the external-facing Privacy Notice published on [Company Name]'s website, which describes how the company processes personal data of its website visitors and contacts. Both documents must remain consistent with each other.

2. Scope

This Policy applies to:

- All personal data processed by [Company Name] as a Data Controller — where the company determines the purposes and means of processing
- All personal data processed by [Company Name] as a Data Processor — where the company processes data on behalf of another controller
- All employees, contractors, and third parties who process personal data on behalf of [Company Name]
- All systems, platforms, and processes used to collect, store, use, share, or dispose of personal data
- Personal data of all categories of data subjects: employees, job applicants, clinical trial participants, patients, customers, suppliers, and website users

Where [Company Name] acts as a Data Processor, the obligations of the relevant Data Processing Agreement (DPA) with the controller govern in addition to this Policy. Where the DPA imposes stricter requirements than this Policy, the DPA prevails for that processing activity.

This Policy applies globally. Where local privacy law imposes stricter requirements than GDPR (the baseline standard applied in this Policy), local requirements prevail for processing activities in that jurisdiction. The DPO maintains a jurisdiction-specific addendum where relevant.

3. Key Definitions

Term	Definition
Personal Data	Any information relating to an identified or identifiable natural person (data subject). Includes names, ID numbers, location data, online identifiers, and factors specific to physical, physiological, genetic, mental, economic, cultural, or social identity.
Special Category Data	Personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data used for unique identification, health data, or data concerning sex life or sexual orientation. Subject to heightened protection.
Data Controller	[Company Name] acting in a capacity where it determines the purposes and means of processing personal data.
Data Processor	[Company Name] or a third party acting in a capacity where it processes personal data on behalf of a controller, under a Data Processing Agreement.
Processing	Any operation performed on personal data: collection, recording, organisation, structuring, storage, adaptation, retrieval, consultation, use, disclosure, dissemination, restriction, erasure, or destruction.
Data Subject	The identified or identifiable natural person to whom personal data relates.
Consent	Freely given, specific, informed, and unambiguous indication of the data subject's wishes by a statement or clear affirmative action.
DPIA	Data Protection Impact Assessment — a process to identify and mitigate privacy risks in new or materially changed processing activities.
PHI	Protected Health Information — individually identifiable health information created, received, maintained, or transmitted by a HIPAA-covered entity or business associate.

4. Data Protection Principles

All personal data processing at [Company Name] must comply with the following principles, which are drawn from GDPR Article 5 and represent the foundation of the company's privacy programme:

Principle	Requirement	Practical Obligation
Lawfulness, Fairness and Transparency	Processing must have a legal basis. Data subjects must be informed how their data is used.	Every processing activity must be documented in the ROPA with its lawful basis. Privacy notices must be provided at the point of data collection. No covert processing.
Purpose Limitation	Data collected for a specified purpose may not be used for an incompatible purpose.	New uses of existing data must be assessed against the original purpose. Incompatible new uses require a new lawful basis or fresh consent. Data Owners must not repurpose data without DPO consultation.
Data Minimisation	Only data that is adequate, relevant, and necessary for the stated purpose should be collected.	Data collection forms and system inputs must be reviewed by the DPO to eliminate unnecessary fields. Retention periods must reflect minimum necessary duration — not maximum possible.
Accuracy	Personal data must be accurate and kept up to date.	Processes must be in place for data subjects to update their information. Inaccurate data must be rectified or erased promptly. Data Owners must implement accuracy checks appropriate to the risk.
Storage Limitation	Personal data must not be kept longer than necessary for the stated purpose.	All personal data must have a retention period per POL-002. Data minimisation applies to duration as well as volume. Automated deletion or anonymisation at end of retention period must be implemented where feasible.
Integrity and Confidentiality	Personal data must be protected against unauthorised or unlawful processing, accidental loss, destruction, or damage.	Tier 4 (Sensitive Personal) and Special Category data must be encrypted at rest and in transit. Access restricted to need-to-know. Systems holding personal data must meet Tier 2 minimum classification under POL-005.
Accountability	The data controller must be able to demonstrate compliance with all of the above principles.	Privacy governance activities must be documented: ROPA, DPIAs, DPAs, consent records, breach notifications, DSR responses. The DPO maintains the evidence base for regulatory inspection.

5. Lawful Bases for Processing

Every processing activity must have a documented lawful basis under GDPR Article 6. For Special Category data, an additional condition under Article 9 must also be documented. The lawful basis must be determined before processing begins — it cannot be changed retrospectively.

Lawful Basis	When It Applies at [Company Name]	Key Limitations
Contractual Necessity (Art. 6(1)(b))	Processing is necessary to fulfil a contract with the data subject (e.g., employment contracts, clinical trial agreements) or to take steps at their request before entering a contract.	Cannot be used for processing that is convenient but not strictly necessary for the contract. Must not be over-relied upon to avoid seeking consent.
Legal Obligation (Art. 6(1)(c))	Processing is required by EU or Member State law (e.g., tax reporting, employment law, pharmacovigilance reporting, GxP record-keeping).	The specific legal obligation must be identified and documented. Cannot be used for processing mandated only by company policy rather than law.
Vital Interests (Art. 6(1)(d))	Processing is necessary to protect the vital interests of the data subject or another person — typically in medical emergency scenarios.	Only applicable where no other lawful basis can reasonably be relied upon. Typically limited to emergency healthcare contexts.
Legitimate Interests (Art. 6(1)(f))	Processing is necessary for the legitimate interests of [Company Name] or a third party, where not overridden by the data subject's interests or rights.	Requires a documented Legitimate Interests Assessment (LIA) balancing company interests against data subject rights. Cannot override fundamental rights. Cannot be used for processing of Special Category data without an Art. 9 condition. Must be reviewed by DPO.
Consent (Art. 6(1)(a))	The data subject has given clear, informed, freely given, specific, and unambiguous consent for the processing.	Consent must be as easy to withdraw as to give. Cannot be bundled with other terms. Employees: genuine consent is rarely achievable due to power imbalance — Legal Obligation or Contract is preferred. Consent records must be maintained per POL-002.
Public Task (Art. 6(1)(e))	Processing is necessary for a task carried out in the public interest — unlikely to apply frequently in a commercial life-sciences context.	Must be based on Union or Member State law. DPO must confirm applicability before reliance.

GxP: Special Category data (health data, genetic data, biometric data, etc.) requires both an Article 6 lawful basis and an Article 9 condition. The most common Article 9 conditions for [Company Name] are: explicit consent (9(2)(a)), employment law obligations (9(2)(b)), clinical trial and medical purposes (9(2)(i)), and public health (9(2)(i)). The DPO must confirm the applicable conditions before

any Special Category data is processed.

6. Records of Processing Activities (ROPA)

[Company Name] maintains a Records of Processing Activities register (ROPA) as required by GDPR Article 30. The ROPA is the authoritative record of all personal data processing activities carried out by the company and is a primary document for regulatory inspection.

The DPO owns and maintains the ROPA. Every new processing activity involving personal data must be registered in the ROPA before processing commences. Data Owners are responsible for notifying the DPO of new or changed processing activities in their domain.

Each ROPA entry must contain:

- Name and contact details of the controller and DPO
- Purpose of the processing and lawful basis
- Categories of data subjects and personal data
- Categories of recipients, including third-party processors and cross-border transfers
- Retention periods
- Description of technical and organisational security measures

The ROPA must be reviewed and updated at least annually and whenever a material change to a processing activity occurs. It must be made available to a supervisory authority on request without delay.

7. Data Protection Impact Assessments (DPIA)

A DPIA is mandatory before commencing any processing likely to result in a high risk to the rights and freedoms of data subjects (GDPR Article 35). At [Company Name], a DPIA must be conducted for:

- Any new system or process that involves large-scale processing of Special Category data (including clinical trial data, health records, genetic data)
- Any systematic and extensive profiling or automated decision-making with significant effects on individuals
- Any large-scale processing of personal data from a publicly accessible area
- Any deployment of new technology that has not been previously assessed — including AI/ML tools, wearables, or biometric systems
- Any cross-border transfer of personal data to countries without an adequacy decision, where a Transfer Impact Assessment (TIA) is also required
- Any processing activity identified as high risk in a preliminary screening conducted by the DPO

DPIA Step	Description	Responsible
Screening	DPO or designee conducts preliminary screening using a standardised questionnaire to determine if a full DPIA is required.	Data Owner + DPO
Scoping	Define the processing activity, data types, system, purpose, and data flows. Document in DPIA template.	Data Owner + DPO
Risk identification	Identify privacy risks to data subjects — likelihood and severity of harm.	DPO + Data Owner
Measures	Document technical and organisational measures to mitigate identified risks. Assess residual risk.	Data Owner + IT + DPO
Approval	DPO approves DPIA. If residual risk remains high and cannot be mitigated, the supervisory authority must be consulted before processing commences (GDPR Art. 36).	DPO (+ supervisory authority if required)
Review	DPIA reviewed when the processing activity changes materially or every 3 years.	DPO + Data Owner

8. Data Subject Rights

Under GDPR and applicable privacy law, data subjects have the following rights. [Company Name] must be able to respond to each within the statutory timeframe. The DPO coordinates all data subject requests (DSRs).

Right	Description	Response Deadline	Conditions / Limitations
Right of Access (Art. 15)	Data subject may request confirmation of whether their data is processed and a copy of the data.	1 month (extendable to 3 months for complex requests)	Must provide data in structured, commonly used format. Fee may be charged for manifestly unfounded or excessive requests.
Right to Rectification (Art. 16)	Data subject may request correction of inaccurate or completion of incomplete data.	1 month	Must notify all recipients of the rectification unless disproportionate.
Right to Erasure (Art. 17)	Data subject may request deletion of their data ('right to be forgotten').	1 month	Multiple exemptions apply: legal obligation, public interest, research, legal claims. GxP records cannot be erased before regulatory minimum retention. Legal must confirm before any erasure.
Right to	Data subject may	Implement	Data may be stored but not processed

Right	Description	Response Deadline	Conditions / Limitations
Restriction (Art. 18)	request that processing is restricted while a dispute is resolved.	restriction promptly upon request	further during restriction. Notify before lifting restriction.
Right to Data Portability (Art. 20)	Data subject may request their data in a machine-readable format for transfer to another controller.	1 month	Only applies where lawful basis is consent or contract, and processing is automated.
Right to Object (Art. 21)	Data subject may object to processing based on legitimate interests or for direct marketing.	Must cease processing immediately for direct marketing; assess other objections	Processing based on legitimate interests: must cease unless compelling legitimate grounds override data subject interests.
Right to Withdraw Consent	Where consent is the lawful basis, data subject may withdraw at any time.	Effect must be immediate	Does not affect lawfulness of processing before withdrawal. Alternative lawful basis must be assessed.
CCPA Rights	California residents: right to know, delete, opt-out of sale, and non-discrimination.	45 days (extendable to 90 days)	Applies to California consumers. DPO maintains CCPA-specific response process.
HIPAA Individual Rights	Access, amendment, accounting of disclosures, restriction requests.	30–60 days depending on right	Applies to PHI held by covered entities / business associates. Privacy Officer coordinates.

All DSRs must be logged in the DSR register maintained by the DPO. Identity verification must be carried out before disclosing any data. DSR records must be retained per POL-002.

9. Special Category and Children's Data

9.1 Special Category Data

Special Category data (as defined in Section 3) is subject to the highest level of protection. In addition to all other requirements of this Policy, the following mandatory controls apply:

- Processing must not commence without written confirmation from the DPO of the applicable Article 9 condition
- A DPIA is mandatory before any new Special Category data processing activity begins
- Access must be strictly limited to named individuals with a documented business need — no blanket role-based access
- Encryption at rest and in transit is mandatory using approved cryptographic standards
- Special Category data must be stored in systems classified at a minimum of Tier 2 — Critical under POL-005
- Pseudonymisation must be applied wherever it is technically feasible without compromising the purpose of processing
- Third parties processing Special Category data on behalf of [Company Name] must be assessed to an enhanced standard under POL-013

9.2 Clinical Trial Participant Data

Data relating to clinical trial participants is both Special Category data and GxP-regulated. Additional requirements apply:

- Processing must comply with ICH E6(R2) Good Clinical Practice, applicable national clinical trial regulations, and the trial's approved protocol
- Participant data must be pseudonymised in the clinical database — the re-identification key must be held separately under controlled access
- All participant data processing must be governed by an approved Informed Consent Form (ICF) — data collected outside the scope of consent is prohibited
- Data transfers to sponsors, CROs, or regulatory authorities must comply with Section 10 of this Policy and the applicable DPA

9.3 Children's Data

Processing of personal data relating to children (under 16 in the EU, or lower age threshold where applicable national law requires) is subject to enhanced obligations:

- Parental or guardian consent must be obtained for processing based on consent
- Privacy information must be presented in clear, child-friendly language
- Any new processing activity involving children's data requires a DPIA
- The DPO must be consulted before any product, service, or process is designed that may involve children's data

10. International Data Transfers

Transferring personal data outside the European Economic Area (EEA), or from the UK or other jurisdictions with transfer restrictions, is subject to legal controls. No such transfer may take place without a valid transfer mechanism in place.

Transfer Mechanism	Description	When to Use
Adequacy Decision	The European Commission or UK Government has recognised the destination country as providing adequate protection.	Transfers to adequacy-listed countries (e.g., Japan, Canada, New Zealand for GDPR; US under UK-US data bridge where applicable). Confirm current adequacy status with DPO before relying upon — decisions can be revoked.
Standard Contractual Clauses (SCCs)	EU Commission-approved contractual terms incorporated into the transfer agreement, supplemented by a Transfer Impact Assessment (TIA).	Transfers to countries without an adequacy decision, including the US (except where adequacy applies). TIA must confirm SCCs provide effective protection in practice.
Binding Corporate Rules (BCRs)	Intra-group transfer mechanism approved by a lead supervisory authority, enabling personal data transfers within the [Company Name] corporate group.	Intra-group transfers between group entities in different jurisdictions. Requires regulatory approval — DPO coordinates.
Derogations (Art. 49)	Transfers based on explicit consent, contractual necessity, or vital interests — only where no other mechanism is available.	Last resort only. DPO must confirm no alternative transfer mechanism is available. Explicit consent from data subject required where consent is the basis.
UK International Data Transfer Agreement (IDTA)	UK-specific equivalent of SCCs for transfers from the UK.	Transfers of data originally received under UK GDPR to countries outside the UK without adequacy.

All international transfer arrangements must be registered in the ROPA and reviewed at least annually. Any change in the legal or technical landscape of the destination country (e.g., government surveillance laws) must trigger a review of the TIA.

11. Personal Data Breach Notification

A personal data breach is any security incident that leads to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. All suspected or confirmed breaches must be reported immediately to the DPO and Information Security.

Timeline	Obligation	Responsible
Immediate (on discovery)	Report the suspected or confirmed breach to the DPO and Information Security. Do not attempt to investigate or remediate without notifying them first.	All Personnel
Within 1 hour	DPO and CISO assess severity. Incident Response Policy (POL-012) is activated. Data Owner notified.	DPO + CISO
Within 24 hours	DPO completes initial breach assessment: categories and approximate volume of personal data affected; likely consequences; Data Owners identified.	DPO + Data Owner
Within 72 hours (GDPR Art. 33)	If the breach is likely to result in a risk to the rights and freedoms of natural persons, notification must be made to the relevant supervisory authority (e.g., ICO, DPA). Notification must include: nature of breach, categories and number of records, likely consequences, and measures taken.	DPO (+ Legal)
Without undue delay (GDPR Art. 34)	If the breach is likely to result in a high risk to data subjects, the affected individuals must be notified directly — in clear, plain language — of the breach and what they should do to protect themselves.	DPO (+ Legal + Communications)
HIPAA — 60 days	Notification to HHS Secretary (and affected individuals if >500 in a state, media notification also required).	Privacy Officer + Legal
Post-breach	Root cause analysis. CAPA. Breach register updated. Annual breach summary to ISSG.	DPO + Information Security

IMPORTANT: The 72-hour GDPR notification clock starts from when [Company Name] becomes aware of the breach — not when it is confirmed. When in doubt, notify the supervisory authority. It is better to notify and subsequently close the matter than to miss the deadline.

12. Third-Party Processors

Where [Company Name] engages a third party to process personal data on its behalf, the following requirements apply:

- A Data Processing Agreement (DPA) compliant with GDPR Article 28 must be in place before processing begins

- The DPA must specify: the subject matter, duration, nature and purpose of processing, type of data, categories of data subjects, and the obligations and rights of the controller
- The processor must only process data on documented instructions from [Company Name]
- The processor must implement appropriate technical and organisational security measures
- Sub-processors may only be engaged with prior written authorisation from [Company Name]
- Third-party processors must be assessed under POL-013 (Third Party and Vendor Risk Policy) before engagement
- Annual processor reviews must confirm ongoing compliance with the DPA

Where [Company Name] acts as a processor for a third-party controller, the same DPA requirements apply from the other direction. The DPO must review any agreement under which [Company Name] accepts processor obligations.

13. HIPAA Compliance

Where [Company Name] is a HIPAA-covered entity or business associate, the following additional requirements apply to processing of Protected Health Information (PHI):

- A Business Associate Agreement (BAA) must be in place with all business associates who receive, create, maintain, or transmit PHI on behalf of [Company Name]
- PHI must be safeguarded with the administrative, physical, and technical safeguards defined in the HIPAA Security Rule (45 CFR Part 164, Subpart C)
- Minimum Necessary standard applies — only the minimum necessary PHI must be used, disclosed, or requested for any particular purpose
- A HIPAA Privacy Officer is designated by [Company Name] and is responsible for HIPAA compliance programme management
- All workforce members who access PHI must complete HIPAA training annually
- HIPAA breach notification requirements (Section 11) apply in parallel with GDPR notification obligations where both regulations govern the same breach

14. Roles and Responsibilities

Role	Privacy Responsibility
Data Protection Officer (DPO)	Statutory role (GDPR Art. 37). Advises on all privacy matters. Owns the ROPA, DPIA programme, DSR process, and breach notification process. Monitors compliance. Acts as supervisory authority contact. Independent — cannot be instructed by management on how to perform statutory

Role	Privacy Responsibility
	functions.
Data Owner	Ensures personal data in their domain has a documented lawful basis and ROPA entry before processing begins. Triggers DPIA screening for new processing. Responds to DSR queries relating to their data domain. Initiates breach reporting.
Legal / Compliance	Drafts and reviews DPAs, BAAs, SCCs, and consent mechanisms. Advises on cross-border transfer mechanisms. Supports regulatory authority engagement. Manages legal hold obligations where they intersect with privacy.
Information Security	Implements technical controls for Tier 4 personal data (encryption, access controls, monitoring). Manages breach detection and response (POL-012). Supports DPO with TIAs for cross-border transfers.
Data Custodian (IT)	Implements deletion schedules for personal data per POL-002 and this Policy. Configures pseudonymisation and access controls. Executes DSR-related technical operations (erasure, export).
All Personnel	Process personal data only for documented, authorised purposes. Do not share personal data externally without DPO / Legal confirmation. Report suspected breaches immediately. Complete annual privacy training.

15. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-001	Data Classification Policy	Tier 4 (Sensitive Personal) classification governed by this Policy
POL-002	Data Retention and Disposal Policy	Retention periods for personal data; data minimisation principle constrains maximum retention
POL-003	Data Integrity Policy	ALCOA+ applies to clinical trial personal data; audit trail requirements
POL-005	System Classification Policy	Systems holding personal data: minimum Tier 2 classification
POL-006	Computer System Validation and Qualification Policy	Track A and Track C qualification documentation provides Article 32 (GDPR) evidence of technical measures for systems processing personal data; DPIA technical measure commitments are fulfilled through the applicable assurance track
POL-008	Access Control Policy	Access controls for Tier 4 and Special Category

Document ID	Title	Relationship
		data systems — Article 32 GDPR and HIPAA Security Rule technical measure
POL-009	Privileged Access Management Policy	Privileged access to systems holding PHI, Special Category data, or clinical trial participant data requires PAM controls; session recording for Tier 1/2 systems supports GDPR Article 32 accountability and HIPAA audit requirements
POL-012	Incident Response Policy	Breach detection and response — feeds into breach notification process
POL-013	Third Party and Vendor Risk Policy	Processor assessment and DPA requirements
SOP-004	Privacy Process	Operationalises this Policy — DPIA, DSR, and ROPA processes (planned)
EXC-001	Exception Management Policy and Register	Privacy exceptions require mandatory DPO involvement; processing personal data without a valid legal basis is non-approvable per EXC-001 Section 5; international transfers without an adequate mechanism are non-approvable; GDPR supervisory authority notification assessment required for approved privacy exceptions
RACI-001	Roles, Responsibilities and Authorities	Privacy domain accountability mapping

— End of Document —

POL-004 v1.0 DRAFT | [Company Name] | CONFIDENTIAL

[Amendment Section] Test Data Management and Data Masking

This section addresses GDPR Article 25 (data protection by design and by default), ISO 27001 A.8.11, and the general data minimisation principle under GDPR Article 5(1)(c). It governs the use of personal data in non-production environments (development, test, QA, staging, demonstration, and training environments). It applies whether or not production personal data is currently used in these environments — the policy is in place to govern any future instance where such use might be considered, and to establish the default position that production personal data must not be used in non-production environments.

Context note: [Company Name] does not currently use production personal data in non-production environments. This section is a precautionary control that governs any future scenario where such use might be requested, and establishes the approval and safeguarding requirements that must be met before any production data use in test could be authorised.

Default Position: Prohibition on Production Personal Data in Non-Production Environments

The default position is that production personal data — including any data that is, or could be, linked to an identifiable living individual — must not be copied, extracted, or made accessible in any non-production environment. This includes: development environments; test environments; QA and staging environments; demonstration, pilot, or proof-of-concept environments; training environments; and sandbox or analytics environments operating outside production access controls.

This prohibition applies regardless of: the stated purpose of the non-production environment; whether the data will be "anonymised later" (data must be anonymised before moving to the non-production environment, not after); the volume of data involved; or whether the non-production environment is hosted by a trusted internal team.

GDPR Art. 25 requirement: Data protection by design requires that personal data is not used in non-production environments unless there is a specific, documented, and proportionate justification. "It is easier to test with real data" is not a valid justification. The burden of proof is on the team requesting production data use to demonstrate that adequate synthetic or anonymised data is not technically feasible for the specific testing requirement.

Required Approach: Synthetic and Anonymised Test Data

All non-production environments must be populated using one of the following approved approaches, applied before any data enters the non-production environment:

Option 1 — Synthetic data (preferred): Artificially generated data that mirrors the structure, format, data types, and statistical distribution of production data without containing any actual production records. Synthetic data is the preferred option as it eliminates personal data exposure risk entirely. Test coverage with synthetic data must be confirmed adequate before any other option is considered.

Option 2 — Anonymised data: Production data from which all identifying information has been irreversibly removed or transformed such that no individual is reasonably re-identifiable, taking into account all means reasonably likely to be used by an attacker (including combination with other datasets). Anonymisation must meet the standard in Recital 26 of the GDPR — pseudonymisation alone is not anonymisation and does not satisfy this option. Anonymisation technique, tools used, and the risk assessment confirming irreversibility must be documented before the data enters the non-production environment.

Option 3 — Pseudonymised data (restricted use): Production data in which direct identifiers have been replaced with pseudonyms (tokens, hashes, or surrogate keys). Pseudonymised data remains personal data under GDPR. It may be used in non-production environments only where: the mapping key (pseudonymisation table) is held in a separately controlled environment to which non-production users have no access; the non-production environment has access controls equivalent to production (same user access governance under POL-008, same logging and monitoring); and DPO approval has been obtained. Pseudonymised data in a non-production environment without these controls is a personal data exposure.

Approval Process for Exceptional Production Data Use

Where a business or technical team believes that production personal data must be used in a non-production environment — because synthetic or anonymised data genuinely cannot satisfy the testing requirement — the following approval process must be completed before any production data is accessed in the non-production environment. No exception is available for

Special Category personal data or PHI in non-production environments under any circumstances.
Step 1 — Business case: The requesting team documents: (a) the specific testing requirement that cannot be met with synthetic or anonymised data, with technical evidence; (b) the minimum volume and scope of production data needed; (c) the non-production environment security posture; (d) the intended retention period of production data in the non-production environment (must be the minimum necessary and must not exceed 30 days without further DPO review).
Step 2 — DPIA: A Data Protection Impact Assessment is completed under SOP-004 for the proposed production data use in non-production. The DPIA must assess: the risk to data subjects if the non-production environment is compromised; whether the non-production environment has equivalent access controls, logging, and monitoring to the production environment; and the risk of production data becoming permanently embedded in non-production infrastructure (backup schedules, version control, log files). The DPIA must conclude that the risks are acceptable or that adequate mitigations exist before the request proceeds.
Step 3 — Approval: DPO approval is required for any use of production personal data in a non-production environment. For GxP-classified systems: Compliance/QA Director co-approval is also required. Approvals are documented in the exception register under EXC-001 with a maximum duration of 30 days (renewable with DPO review). Approval is granted for a specific purpose and volume; any extension of scope requires a new approval.
Step 4 — Safeguards during use: If approved: (a) access to the non-production environment must be restricted to the minimum set of named individuals who need the production data for the specific test; (b) access controls, logging, and monitoring are configured to the same standard as the production environment; (c) the data must not be copied further (no sub-environments, no laptop exports, no email attachments); (d) Information Security monitors access during the approved period.
Step 5 — Deletion on completion: When testing is complete (or the approved period expires, whichever is sooner): production data must be deleted from all non-production environments including backups, logs that contain personal data fields, and any artefacts generated during the test. Deletion is confirmed in writing to the DPO by the Data Custodian (IT) and the requesting team, with the deletion method documented per POL-002. GxP data: deletion from the non-production environment must also be recorded in the originating system's audit trail.

GxP Test Environments

Test environments for GxP-classified systems are subject to additional constraints under POL-006 (Computer System Validation). GxP test data management obligations include:
Separation of test and production: GxP validated production systems must be physically or logically separated from their test/development equivalents. Test environments must not be able to write to production data stores. This separation is a validated configuration that is change-controlled under POL-007/SOP-007.
Test data qualification: Test data sets used in qualification protocols (IQ/OQ/PQ) must be documented and version-controlled. Test data created during validation retains the test data classification and must not be commingled with production records. The test data set used in a qualification protocol is part of the validation documentation and is retained for the life of the system plus the applicable regulatory retention period.
Prohibition on production patient/subject data in GxP test: Clinical trial data, subject safety data, and batch records must never be used as test data. This is an absolute prohibition under ICH E6 and 21 CFR Part 312 principles: test activities must never create risk to subject safety records or GxP data integrity. No exception is available under EXC-001 for this prohibition.

Roles and Responsibilities

DPO: Approve any use of production personal data in non-production environments. Confirm adequacy of anonymisation where Option 2 is used. Review DPIAs (Step 2). Confirm deletion on completion.
Data Custodian (IT): Implement technical controls separating production from non-production data. Execute approved data extracts with masking/anonymisation applied before delivery to non-production. Confirm deletion on completion.
Information Security: Assess non-production environment security posture as part of DPIA. Monitor access during any approved production data use period. Confirm deletion.
Data Owner (requesting business team): Prepare the business case (Step 1). Use only the minimum necessary data within the approved scope. Notify Data Custodian (IT) and DPO when testing is complete so deletion can proceed.
Compliance/QA Director: Co-approve any production data use in non-production environments for GxP-classified systems. Ensure GxP test data management obligations are met in validation activities.